

CENTINEL

Auditoria Integral del Sistema

Fecha: 7 de junio de 2026

Proyecto: VectisDev/centinel

Agentes auditores: 15 especializados

Este documento consolida las opiniones de los 15 agentes especializados del equipo de auditoria de Centinel. Cada seccion representa un dominio de evaluacion independiente con hallazgos, calificaciones y recomendaciones especificas.

Indice de Secciones

1. Seguridad y Red Team
2. Arquitectura y Calidad de Codigo
3. UX y Accesibilidad
4. Cumplimiento y Documentacion
5. Infraestructura y DevOps
6. Backend Python
7. Criptografia e Integridad de Datos
8. Estadistica Forense (PhD)
9. Financiamiento Estrategico
10. Estrategia Legal
11. Evaluacion de Impacto (MEL)
12. Estandares Internacionales
13. Seguridad OSINT
14. Control Financiero (Costo Cero)
15. Motor de Reglas

1. Seguridad y Red Team

El agente de seguridad y red team evaluo la postura de seguridad general del sistema Centinel, incluyendo superficie de ataque, vectores de amenaza y contramedidas implementadas.

Hallazgos Principales

1. Autenticacion basada en seeds: PBKDF2-SHA256 con 600,000 iteraciones y 12 slots de acceso. Implementacion solida pero el almacenamiento de hashes en repositorio publico requiere atencion.
2. PAT cifrado con AES-256-GCM + HKDF key wrapping: Implementacion criptografica robusta para proteger tokens de GitHub.
3. Cadena de custodia criptografica: SHA-256 encadenado + Merkle root anclado a Bitcoin via OpenTimestamps. Modelo de confianza solido.
4. Superficie de ataque web: GitHub Pages estatico reduce significativamente la superficie. No hay backend propio expuesto.
5. Dependencias CDN sin SRI: 4 librerias externas (js-yaml, chart.js, jszip, jspdf) se cargan sin Subresource Integrity. Vector de supply chain.
6. Session management: sessionStorage para tokens con TTL de 8 horas. Vulnerable a XSS si CDN se compromete.

Calificacion: 7/10

Fortalezas en criptografia y arquitectura de confianza cero. Debilidades en proteccion de supply chain (CDN sin SRI) y exposicion de hashes en repositorio publico.

2. Arquitectura y Calidad de Código

El agente de arquitectura evalúa la estructura del código, patrones de diseño, modularidad y mantenibilidad del sistema.

Hallazgos Principales

1. Separación clara: web/ (frontend estático), src/centinel/ (motor), command_center/ (configuración), scripts/ (utilidades). Buena estructura.
2. Motor de reglas con patrón decorador @rule: Extensible, cada regla es un archivo independiente con metadatos. 24 reglas registradas.
3. Pipeline de datos bien definido: Captura -> Normalización -> Hashing -> Diff -> Reglas -> Anclaje -> Publicación.
4. web/ops/index.html: Archivo monolítico de ~4,889 líneas (ahora modularizado en ops-core.js, ops-panel.js, ops-monitor.js). Mejora significativa.
5. Documentación bilingüe consistente (EN/ES) en todos los módulos.
6. Tests: 526 tests pasando. Cobertura desigual entre módulos.

Calificación: 7.5/10

Arquitectura sólida para el dominio. La modularización reciente del panel ops es una mejora importante. Necesita más tests unitarios para reglas individuales.

3. UX y Accesibilidad

El agente de dashboard y visualizacion evaluo la experiencia de usuario del panel de operaciones y las interfaces publicas.

Hallazgos Principales

1. Diseno SpaceX: Consistente, profesional, identidad visual fuerte. Variables CSS bien organizadas con tema oscuro.
2. Modo Facil/Completo: Buena decision de UX para operadores de diferentes niveles tecnicos.
3. Auto-save con debounce 1.5s: Reduce friccion operativa. Ahora activado por defecto (mejora reciente).
4. Panel responsive: Funciona en movil pero con limitaciones en tablas complejas y mapas.
5. Accesibilidad: Falta de atributos ARIA, contraste insuficiente en algunos elementos muted, sin soporte de teclado completo.
6. Log de auditoria de sesion: Ahora incluye fingerprint criptografico del operador (ultimos 6 caracteres del hash PBKDF2).

Calificacion: 6.5/10

Visualmente profesional y funcional. Necesita mejoras en accesibilidad (WCAG 2.1) y soporte movil mas robusto.

4. Cumplimiento y Documentacion

El agente de cumplimiento evaluo la documentacion del proyecto, licencias, disclaimers y cumplimiento regulatorio.

Hallazgos Principales

1. Documentacion extensa: README bilingue, METHODOLOGY.md con 30 detectores documentados, RULES.md con catalogo completo.
2. Inconsistencia de licencia: LICENSE dice AGPL-3.0 pero LICENSE_COMMITMENT.md menciona MIT. Requiere correccion inmediata.
3. Disclaimer legal: "CENTINEL no afirma fraude" presente y correcto en README y documentacion publica.
4. Dev diary: 30+ entradas documentando decisiones de diseno. Excelente trazabilidad de decisiones.
5. Documentacion de grants: BUDGET_NARRATIVE, REGIONAL-NARRATIVE, EXECUTION-PLAN completos y profesionales.
6. SECURITY.md y SECURITY_AUDIT.md presentes con politica de divulgacion.

Calificacion: 7/10

Documentacion rica y profesional. La inconsistencia de licencia (AGPL vs MIT) es el hallazgo critico que requiere resolucion urgente.

5. Infraestructura y DevOps

El agente de operaciones evaluo la infraestructura CI/CD, despliegue, monitoreo y resiliencia del sistema.

Hallazgos Principales

1. CI/CD: 22 workflows de GitHub Actions cubriendo CI, despliegue, gossip, hash chain, seeds, observador, etc.
2. GitHub Pages: Despliegue costo cero, sin servidor propio. heal_web.py como mecanismo de auto-reparacion.
3. Docker: Dockerfile multi-stage con healthchecks estrictos y restart agresivo. Produccion-ready.
4. Monitoreo: Prometheus metrics, heartbeat.json con validacion de antiguedad (< 600s).
5. Resiliencia: Circuit breaker, retry con backoff, graceful degradation documentados.
6. Uso de Actions: ~35 min/mes de 2,000 disponibles. Holgura significativa pero runners macOS/Windows no contabilizados.

Calificacion: 8/10

Infraestructura madura para un proyecto de costo cero. Los workflows estan bien organizados y el sistema de auto-reparacion es innovador.

6. Backend Python

El agente de backend evaluo la calidad del codigo Python, el pipeline de datos y la robustez del motor de analisis.

Hallazgos Principales

1. Python 3.10+: Uso moderno de type hints, dataclasses, f-strings. pyproject.toml como fuente canonica.
2. Pipeline robusto: Captura con retry, normalizacion multi-formato, hashing determinista, diff incremental.
3. Manejo de errores: try/except con logging estructurado (JSON). Cada regla aislada -- error en una no detiene las demas.
4. Dependencias: Todas OSS. scipy, scikit-learn, pandas para analisis. web3 para blockchain. cryptography para firmas.
5. Tests: conftest.py con fixtures compartidas. Tests de integracion E2E simulando ciclo electoral completo.
6. Federacion: Protocolo gossip via GitHub Issues, hash chain export, reputation model. Arquitectura P2P genuina.

Calificacion: 7.5/10

Backend bien estructurado con pipeline robusto. Necesita mas tests unitarios para reglas individuales y mejor validacion de esquema de configuracion al arranque.

7. Criptografia e Integridad de Datos

El agente de criptografia evaluo los mecanismos de integridad, cadena de custodia y anclaje temporal del sistema.

Hallazgos Principales

1. Hash chain: SHA-256 encadenado por snapshot con previous_hash. Modelo Merkle para verificacion eficiente.
2. OpenTimestamps: Anclaje a Bitcoin via calendarios publicos (alice.btc, bob.btc, pool a/b/c). Costo \$0.
3. AES-256-GCM + HKDF: Cifrado de PAT con key wrapping por seed. Implementacion correcta con nonce aleatorio de 12 bytes.
4. PBKDF2-SHA256: 600,000 iteraciones para derivacion de seeds. Parametros adecuados para 2026.
5. Verificacion determinista: Cualquier tercero puede verificar offline con solo el repositorio y los datos.
6. Mesa fingerprint: SHA-256 por mesa individual para detectar modificacion post-publicacion de actas.

Calificacion: 8.5/10

Punto mas fuerte del sistema. La cadena criptografica es solida, verificable y anclada a Bitcoin. Minor: considerar migracion a SHA-3 para future-proofing.

8. Estadística Forense (PhD)

El agente de estadística forense (nivel PhD) evaluó el rigor matemático de los 30 detectores estadísticos implementados.

9 Hallazgos por Prioridad

ALTA PRIORIDAD:

1. Benford sobre series temporales: La Ley de Benford se aplica a totales acumulados por snapshot, pero estos son series temporales correlacionadas, no muestras independientes. Los p-valores del chi-cuadrado están inflados.
2. min_samples demasiado bajo: min_samples=10 en Benford es insuficiente. La literatura recomienda $n \geq 100$ para estabilidad estadística. Riesgo de falsos positivos.
3. Sin corrección de multiplicidad: 30 detectores corriendo simultáneamente sin corrección Bonferroni/BH. Con $\alpha=0.05$ y 30 tests, la probabilidad de al menos un falso positivo es 79%.

MEDIA PRIORIDAD:

4. Correlación sin verificar supuestos: Pearson r asume normalidad bivariada y relación lineal. Los datos electorales raramente cumplen.
5. Runs test: Depende del ordenamiento de mesas. Sin definición canónica de orden, los resultados no son reproducibles.
6. Isolation Forest contamination=0.1: Asume 10% de outliers a priori. Sin calibración empírica.

BAJA PRIORIDAD:

7. Z-score con distribuciones no normales: Deltas electorales son frecuentemente sesgados. Z-score puede distorsionarse.
8. Umbrales sin calibración: Valores como mad_threshold=0.015 y chi_square_p=0.05 son convencionales, no calibrados empíricamente.
9. Sin tests adversariales: No hay suite que genere datos específicamente diseñados para evadir los detectores.

Calificación: 6/10

Catálogo impresionante de 30 detectores pero con debilidades estadísticas fundamentales. La corrección de multiplicidad y los min_samples son correcciones urgentes antes de presentar resultados ante observadores internacionales.

9. Financiamiento Estrategico

El agente de financiamiento estrategico evaluo la preparacion del proyecto para aplicar a grants y fondos internacionales.

Evaluacion por Dimension

Dimension	Nota	Observacion
Teoría del Cambio	8/10	Solida, necesita indicadores medibles
Presupuesto	7.5/10	Eficiente, Supabase eliminado pero en budget
M&E Framework	5/10	Debil, sin baseline ni indicadores SMART
Sostenibilidad	7/10	Costo cero post-grant es creible
Posicionamiento	8.5/10	Unico en la region, ventaja competitiva
Narrativa	9/10	Compelling, Honduras 2017/2025 como evidencia

Listo para OTF y NED. No listo para USAID o UE sin framework M&E formal y entidad legal constituida. La narrativa regional (Honduras 2017/2025, Guatemala 2023, El Salvador 2024) es excepcionalmente fuerte y diferenciadora.

10. Estrategia Legal

El agente legal evaluo el marco juridico, riesgos legales y cumplimiento normativo del proyecto.

Hallazgos Principales

CRITICO: Inconsistencia de licencia

LICENSE declara AGPL-3.0. LICENSE_COMMITMENT.md menciona transicion a MIT. Esto genera ambigüedad legal para contribuidores y usuarios. Resolucion urgente requerida.

Base constitucional: APROBADA

El monitoreo de datos publicos esta protegido por libertad de expresion e informacion en Honduras (Art. 72-74 Constitucion). No requiere acreditacion formal.

Admisibilidad de evidencia: RIESGO MEDIO

La cadena criptografica (SHA-256 + OpenTimestamps) establece integridad y temporalidad, pero la admisibilidad como prueba judicial requiere peritaje informatico formal.

Disclaimer: CORRECTO

"CENTINEL no afirma fraude" esta presente en todas las interfaces publicas y documentacion. Posicion juridicamente defensible.

Riesgo de demanda: BAJO-MEDIO

El CNE podria alegar interferencia en procesos electorales, pero el uso exclusivo de datos publicos y la ausencia de intrusion hacen este argumento debil.

Calificacion: 6.5/10

Posicion legal generalmente solida pero la inconsistencia de licencia es un riesgo real para adopcion institucional.

11. Evaluacion de Impacto (MEL)

El agente de evaluacion de impacto evaluo el sistema de Monitoreo, Evaluacion y Aprendizaje del proyecto.

Evaluacion por Dimension

Dimension	Nota	Observacion
Metodologia	8/10	30 detectores documentados, reproducibles
Teoria del Cambio	7/10	Articulada pero sin indicadores SMART
Sostenibilidad	7/10	Costo cero es ventaja estructural
Genero/Inclusion	1/10	Ausencia total de analisis de genero
Contrafactual	2/10	Sin grupo de control ni baseline
Agenda de Aprendizaje	3/10	Sin plan de iteracion sistematico
Do No Harm	4/10	Riesgos para operadores no mitigados
Promedio	4.8/10	Fuerte en tecnico, debil en social

El sistema es tecnico-centric: excelente en metodologia estadistica y criptografica, pero con brechas graves en dimensiones sociales requeridas por donantes internacionales (genero, contrafactual, Do No Harm). Priorizar framework de genero e inclusion antes de aplicar a grants de USAID o cooperacion europea.

12. Estándares Internacionales

El agente de estándares internacionales evalúa la alineación del sistema con marcos de observación electoral reconocidos.

Cumplimiento por Estándar

Estándar	Nota	Observación
ONU Declaración 2005	6/10	Sin acreditación formal
OEA/DECO	6/10	Detección alineada, reporte pendiente
Observación UE	5/10	Cobertura parcial del ciclo electoral
Carter Center	7/10	Cadena de custodia fuerte
NDI/IRI	7/10	Arquitectura P2P alineada
OSCE/ODIHR	5/10	Fuera del ámbito geográfico
Estándares PVT	7/10	Dependencia de publicación del CNE
Forense/Custodia	8/10	Punto más fuerte del sistema
Complemento vs Sustituto	OK	Posición correcta y documentada

Promedio: 6.3/10. Bases técnicas sólidas para complementar misiones de observación internacional. Brechas principales en integración institucional, cobertura del ciclo completo y atestación técnica externa independiente. El sistema se posiciona correctamente como complemento, no sustituto del observador humano.

13. Seguridad OSINT

El agente OSINT evaluo la exposicion de informacion sensible del proyecto y sus operadores en fuentes abiertas.

Hallazgos por Severidad

CRITICO:

1. Identidad del operador expuesta: Git log contiene emails personales vinculables. CONTRIBUTORS.md publica usernames. En contexto hondureno, esto representa riesgo fisico real.

ALTO:

2. access.json publico con hashes: Los 12 hashes de seeds estan en el repositorio publico via GitHub Pages.

3. Seeds comprometidos en historial: Commits de regeneracion de seeds estan en el git log permanentemente.

MEDIO:

4. CDN sin SRI: 4 librerias externas sin Subresource Integrity. Vector de supply chain para exfiltracion de PAT.

5. PAT en sessionStorage: Accesible desde cualquier script en el mismo origen, vulnerable a XSS.

BAJO:

6. User-Agent identificable: "C.E.N.T.I.N.E.L./1.0" permite al CNE identificar y bloquear nodos de monitoreo.

7. Documentacion facilita spear-phishing: Suficiente informacion publica para construir emails de phishing convincentes.

Calificacion: 4/10

Nivel de riesgo OSINT alto. La exposicion de identidad del operador es la preocupacion principal. Se recomienda anonimizacion de git history, rotacion de identidades y adiccion de SRI a CDN.

14. Control Financiero (Costo Cero)

El agente tesorero verifico el cumplimiento de la regla sagrada de operacion a costo cero absoluto del proyecto.

Verificacion por Area

Area	Veredicto	Observacion
BUDGET_NARRATIVE	Parcial	Supabase (\$1,680) eliminado pero en budget
GitHub free tier	Riesgo	macOS/Windows runners no contabilizados
Dependencias OSS	Conforme	100% open-source verificado
Docker hosting	Conforme	\$0 en arquitectura actual
Actions minutes	Riesgo	Subestimacion si repo privado
Servicios terceros	Conforme	ntfy/Sentry/OTel no activos en prod
OpenTimestamps	Conforme	\$0, calendarios publicos absorben fees
Escalabilidad	Parcial	Capa GitHub \$0, analisis tiene costo variable
Costos ocultos	Conforme	SSL/DNS/Bitcoin cubiertos
Capital humano	Conforme	Tarifas regionales apropiadas

Conclusion: La arquitectura central (GitHub Pages + Actions + Issues) es genuinamente costo cero. Riesgos materiales: (a) budget incluye Supabase eliminado; (b) gpu-batch-validation puede consumir free tier; (c) "costo cero a cualquier escala" es verdadero para coordinacion pero el motor estadistico tiene costos variables. El claim de "\$50/mes post-grant" es verificable y creible.

15. Motor de Reglas

El agente de arquitectura de motor de reglas evaluo la estructura, extensibilidad y robustez del sistema de deteccion.

Evaluacion por Dimension

Dimension	Nota	Observacion
Arquitectura	7/10	Patron decorador limpio, registro centralizado
Composicion/Dependencias	4/10	Sin correlacion entre reglas
Gestion de configuracion	6/10	YAML configurable, sin validacion de esquema
Versionado de reglas	2/10	Sin version ni hash de codigo en logs
Falsos positivos	5/10	min_samples configurable, sin supresion dinamica
Priorizacion de alertas	5/10	Solo CRITICAL/HIGH, sin scoring numerico
Cobertura de pruebas	5/10	20 de 24 reglas sin test dedicado
Extensibilidad	8/10	Agregar regla = 1 archivo + 1 import
Rendimiento	6/10	Secuencial, SQLite por ejecucion en ML
Rastro de auditoria	7/10	JSONL completo, sin version de codigo
Promedio	5.5/10	Extensible pero con brechas en versionado

Tres brechas prioritarias: (1) Anadir version a RuleDefinition y registrar hash del config activo en cada log de ejecucion. (2) Implementar composicion basica para correlacionar senales entre reglas. (3) Anadir tests unitarios para las 20 reglas sin cobertura, priorizando benford_first_digit_rule y granular_anomaly_rule.

Resumen Ejecutivo

#	Agente	Nota
1	Seguridad / Red Team	7.0/10
2	Arquitectura / Codigo	7.5/10
3	UX / Accesibilidad	6.5/10
4	Cumplimiento / Documentacion	7.0/10
5	Infraestructura / DevOps	8.0/10
6	Backend Python	7.5/10
7	Criptografia / Integridad	8.5/10
8	Estadistica Forense (PhD)	6.0/10
9	Financiamiento Estrategico	7.5/10
10	Estrategia Legal	6.5/10
11	Evaluacion de Impacto (MEL)	4.8/10
12	Estandares Internacionales	6.3/10
13	Seguridad OSINT	4.0/10
14	Control Financiero	7.5/10
15	Motor de Reglas	5.5/10
	PROMEDIO GENERAL	6.6/10

Top 5 Acciones Prioritarias

1. CRITICO: Resolver inconsistencia de licencia AGPL-3.0 vs MIT.
2. CRITICO: Proteger identidad del operador -- anonimizar git history, eliminar emails personales de CONTRIBUTORS.md.
3. ALTO: Implementar correccion de multiplicidad (Bonferroni/BH) en los 30 detectores estadisticos simultaneos.
4. ALTO: Anadir Subresource Integrity (SRI) a todas las dependencias CDN (js-yaml, chart.js, jszip, jspdf).
5. MEDIO: Desarrollar framework de genero e inclusion para cumplir requisitos de donantes internacionales.

Nota: Esta auditoria fue realizada por 15 agentes especializados operando de forma independiente. Cada seccion representa una evaluacion autonoma desde la perspectiva del dominio del agente. Las calificaciones son relativas al estado del arte en cada campo y al contexto especifico de auditoria electoral en Centroamerica.